Incident Communication Plan

Version: 1.0

Effective Date: 10. December 2025

Owner: Governance, Risk and Compliance (GRC) Manager

Purpose:

This document outlines the requirement for Incident communication plan, it contains the stakeholders to be notified, communication templates, communication protocols and Regulatory Notification Requirements

1. **Stakeholder identification**

The table below outlines all potential stakeholders requiring communication during incidents. Communication team will ensure the incident is communicated to all the employees guided by the incident response manager, the same team will also communicate to external stakeholders including clients, media and regulators.

Stakeholder	Contact Information	Communication Frequency
CISO	TechMed CISO, +1 (xxx)-xxxxxxxx, ciso@techmed.co.ke	Immediate for all incidents
CEO	TechMed CEO, +1 (xxx)-xxxxxxxx, ceo@techmed.co.ke	Immediate for Critical/High incidents
General Counsel	Legal Head, +1 (xxx)-xxxxxxxx, legal@techmed.co.ke	Immediate if breach suspected
Communications	TechMed Commn. +1 (xxx)-xxxxxxxx, commn@techmed.co.ke	Immediate if media attention likely
Law Enforcement	FBI Field Office, Local Police	Per incident severity
Regulatory Authorities	HIPAA, PCI DSS, State Authorities	Per legal requirements

2. Communication Templates

This section provides detailed templates to be utilized for specific communication and common scenarios. The templates are to be populated based on the current incident handled and should be edited to suit the correct and necessary information.

2.1. Initial Incident Notification

Purpose of the template: internal stakeholder communication, to be sent to the CSIRT Team and Management

Template: Initial CSIRT Alert

To: CSIRT Members, CISO

Subject: URGENT - Incident Response Activation: [Incident Number]

Body:

> The Computer Security Incident Response Team (CSIRT) has been activated in response to a suspected security incident.
>
> **Incident Details:** - **Incident Number:** [Incident Number] - **Detection Time:** [Date/Time] - **Severity Level:** [Critical/High/Medium/Low] - **Incident Type:** [e.g., Ransomware, Data Breach] - **Affected Systems:** [List of affected systems]
>
> **Immediate Actions Required:** 1. All CSIRT members should check in via the secure communication channel 2. Review your assigned role and responsibilities 3. Ensure you have access to all necessary tools and systems 4. Stand by for the initial incident briefing at [Time]
>
> **Secure Communication Channel:** [Channel/Platform (best channel to be advised based on incident)]
>
> Do not discuss this incident via email or public channels.

2.2. Executive Briefing

Executive Briefing Template

Template: Status Update for Executive Leadership

To: CEO, CFO, COO, General Counsel

Subject: Incident Status Update - [Incident Number] - [Date/Time]

Body:

> **Executive Summary:**
>
> We are responding to a [Incident Type] incident that was detected at [Time] on [Date]. The incident is currently classified as [Severity Level]. Below is a summary of the current situation and our response.

Current Status: - **Systems Affected:** [List of systems] - **Data at Risk:** [Describe data potentially affected] - **Business Impact:** [Describe impact on operations] - **Estimated Recovery Time:** [Provide estimate if available]

Actions Taken: 1. [Action 1] 2. [Action 2] 3. [Action 3]

Next Steps: 1. [Next step 1] 2. [Next step 2]

Resource Requirements: - [Resource 1] - [Resource 2]

Decision Required: [If applicable, describe decision needed from leadership]

We will provide the next update at [Time] or sooner if the situation changes.

2.3. Customer Notification Template

Template: Breach Notification for Affected Customers

To: Affected Customers

Subject: Important Security Notice – TechMed Solutions

Body:

Dear Valued Customer,

We are writing to inform you of a security incident that may have affected your personal information stored in our systems.

What Happened: On [Date], we discovered that [brief description of incident]. We immediately launched an investigation and engaged external security experts to determine the scope of the incident.

What Information Was Affected: Our investigation has determined that the following information may have been compromised: [list specific data elements, e.g., name, email address, account number].

What We Are Doing: - We have contained the incident and taken steps to prevent further unauthorized access - We are conducting a thorough forensic investigation - We are notifying all affected individuals - We are working with law enforcement and regulatory authorities - We are implementing additional security measures to prevent similar incidents in the future

What You Should Do: 1. Monitor your accounts for any unauthorized activity 2. Consider placing a fraud alert or credit freeze with the credit bureaus 3. Review your account statements regularly 4. Contact us if you notice any suspicious activity

Additional Resources: - [Link to FAQ page] - [Link to credit monitoring offer] - [Contact information for questions]

We sincerely apologize for this incident and any inconvenience it may cause. Your trust is important to us, and we are committed to protecting your information.

Sincerely,

TechMed Solutions Security Team

2.4. Regulatory Notification

Template: HIPAA Breach Notification

To: [Regulatory Authority]

Subject: Breach Notification – TechMed Solutions - [Date]

Body:

Notification of Breach of Unsecured Protected Health Information

Pursuant to 45 CFR § 164.404, TechMed Solutions is notifying you of a breach of unsecured protected health information (PHI).

Breach Details: - **Date of Breach Discovery:** [Date] - **Date Breach Occurred:** [Date range] - **Number of Individuals Affected:** [Number] - **Type of PHI Involved:** [e.g., names, SSNs, medical record numbers] - **Description of Breach:** [Brief description of what happened]

Breach Notification: - Individual notifications were sent on [Date] - Copies of individual notification letters are attached

Mitigation Measures: - [Mitigation measure 1] - [Mitigation measure 2] - [Mitigation measure 3]

Contact Information: For questions regarding this notification, please contact: - [Name, Title, Phone, Email]

Sincerely,

TechMed Solutions

2.5. Public Statement

Template: Media Statement

For Immediate Release

TechMed Solutions Responds to Security Incident

[CITY, STATE] – [Date] – TechMed Solutions announced today that it has discovered and is actively responding to a security incident affecting its systems.

What We Know: On [Date], we discovered evidence of unauthorized access to our systems. We immediately launched an investigation with the assistance of external security experts and have notified law enforcement.

Our Response: - We have contained the incident and taken steps to prevent further unauthorized access - We are conducting a thorough investigation to determine the full scope of the incident - We are notifying all affected individuals and regulatory

authorities as required by law - We are implementing additional security measures to strengthen our defenses

Commitment to Our Customers: The security and privacy of our customers' information is our highest priority. We are committed to transparency and will provide updates as our investigation progresses.

Resources Available: Customers with questions can visit [website] or call [phone number].

About TechMed Solutions: A mid-sized technology company in the healthcare technology industry with over 800 employees across three locations and over 200 healthcare providers across North America.

Media Contact: [Name, Title, Phone, Email]

3. **Communication Protocol and Regulatory Notification Requirement**

Timing

This guideline provides an overview of internal and external notification timelines and requirements.

- **Internal Notification:** Immediate (within 15 minutes of incident confirmation)
- **Executive Briefing:** Within 1 hour of incident confirmation
- **Customer Notification:** Within 60 days of breach discovery (per HIPAA and most state laws)
- **Regulatory Notification:** Within 60 days of breach discovery (per HIPAA); immediately for PCI DSS

Content Guidelines

This guideline provides a baseline on expectations for all communication content.

- **Be Honest:** Provide accurate information about what happened
- **Be Clear:** Use plain language; avoid technical jargon
- **Be Timely:** Provide updates regularly, even if you don't have complete information
- **Be Responsible:** Take accountability and describe steps being taken to prevent future incidents
- **Be Compliant:** Ensure all communications meet legal and regulatory requirements

Approval Workflows

Below chain dictates how external and internal communications are approved for release.

1. **Internal Communications:** Approved by CISO and Incident Response Manager
2. **Executive Communications:** Approved by CISO, CEO, and General Counsel
3. **Customer Communications:** Approved by General Counsel, Communications, and CISO
4. **Regulatory Communications:** Approved by General Counsel
5. **Media Communications:** Approved by Communications, General Counsel, and CEO